# Burner

## Got a take-home from a recruiter?
## Let Burner run it first.

Burner runs the repo the way a candidate would, inside a throwaway Vultr VM full of fake secrets, and shows you what it tried to steal. Then the VM is destroyed.

Vultr Agent Rush · Track 1

`139-84-215-1.sslip.io`

THE ATTACK

# A recruiter sends a take-home. You run `npm start`. Your keys and wallets are gone.

1
### The message
"Senior Backend Engineer, $180–220k. Run our take-home before tomorrow's call. Let's continue on Telegram."

→

2
### The repo
A normal-looking app. Only a few lines are malicious, hidden in a config file, an asset or a VS Code task.

→

3
### npm start
The payload reads ~/.aws, ~/.ssh, .env files, browser passwords and wallet folders, then uploads them.

→

4
### Drained
Wallets emptied. Sometimes the employer is hit next.

**30,000+**
devices infected in 100+ countries

**7,000+**
crypto wallets drained, Dec 2025 – Jul 2026

**$308M**
DMM Bitcoin, 2024: started with a fake recruiter's "pre-employment test"

Joint advisory, 7 agencies in 4 countries, 18 Sep 2026 (BleepingComputer, The Record) · DMM Bitcoin: FBI, DC3 and Japan NPA attribution (BleepingComputer, Dec 2024)

WHY IT GETS THROUGH

# Today's defences either read the code or isolate it. None of them tell the candidate what it does.

### Scanners read. They don't run.

Elastic, Jul 2026: a new variant had **zero antivirus detections** and runs at `npm start`. Socket counts 1,700+ campaign packages that avoid install-time execution.

### Antivirus caught 1 of 2

On our own PC, Windows Defender quarantined the VS Code `folderOpen` sample but **missed the npm-start stealer**.

### "Use a VM" gives no verdict

The FBI says: "insist on using a virtual machine". A VM protects you, but it won't tell you the repo just tried to steal your keys. Most candidates also won't set one up the night before an interview.

> "Every question was designed so that the only way to answer it is to actually run the project."
>
> Steven Li, developer who received a DeFi take-home, Jun 2026

Elastic Security Labs, Jul 2026 · Socket, Apr 2026 · FBI IC3 PSA, 3 Sep 2024

THE MISSING PIECE

# Platforms each solve a piece of this: scanners, sandboxes, VMs, takedowns. Open-source experiments are starting.

### Scanners

Socket, Aikido, GuardDog: read packages, block known-bad. They don't run your take-home.

### Sandboxes

Malware sandboxes run files for analysts, not for a candidate holding a repo link.

### VMs

FBI and Microsoft advise isolation. Isolation keeps you safe but doesn't tell you anything.

### Takedowns

Atlassian removed "hundreds" of repos, but only after victims had already run them.

## Nobody has put the whole puzzle together in a candidate's hands.

Burner: paste the recruiter's message, get a verdict with evidence in a few minutes, and no setup on your side.

HOW BURNER WORKS

# Run it like a candidate. Bait it with fake secrets. Watch what leaves.

READ

### Recruiter message

The LLM extracts the repo link and red flags. The README is screened for prompt injection.

→

BOOT

### Fresh Vultr VM

One VM per scan, pre-armed in a warm pool, used once. The repo runs in gVisor as "dev-laptop".

→

BAIT

### 15 fake secrets

AWS, SSH, .env, GitHub, Solana, Exodus, MetaMask, Chrome passwords. All random and unique per scan.

→

RUN

### Candidate steps

VS Code folderOpen → npm install → npm start → npm test → start again at +45 days.

→

CATCH

### Fake internet

All DNS and TCP go to our sinkhole. Our own CA decrypts HTTPS. Nothing leaves the VM.

## The verdict is rule-based

A fake key is read, and the same key is seen leaving = **MALICIOUS**. We decode base64, hex, gzip, zip, XOR and DNS tunnels. We also flag persistence, `curl | sh` and sandbox checks.

## The LLM drives, it never judges

Vultr Serverless Inference reads the message, plans extra README steps and explains the result in plain English. It can't change the verdict.

THE CONTAINMENT MOMENT

# Every scan gets its own VM. It lives for minutes, then the Vultr API deletes it.

**CREATED**
**112 s**
paste → verdict, pre-armed VM

→

**DETONATED**
**~100 s**
full stealer scan on a warm host

→

**DESTROYED**
**0**
VMs left running

### Cost of one 3-minute scan VM

**$0.0014**
prorated ($20/mo ≈ $0.0274/h)

**$0.027**
worst case: a full hour billed

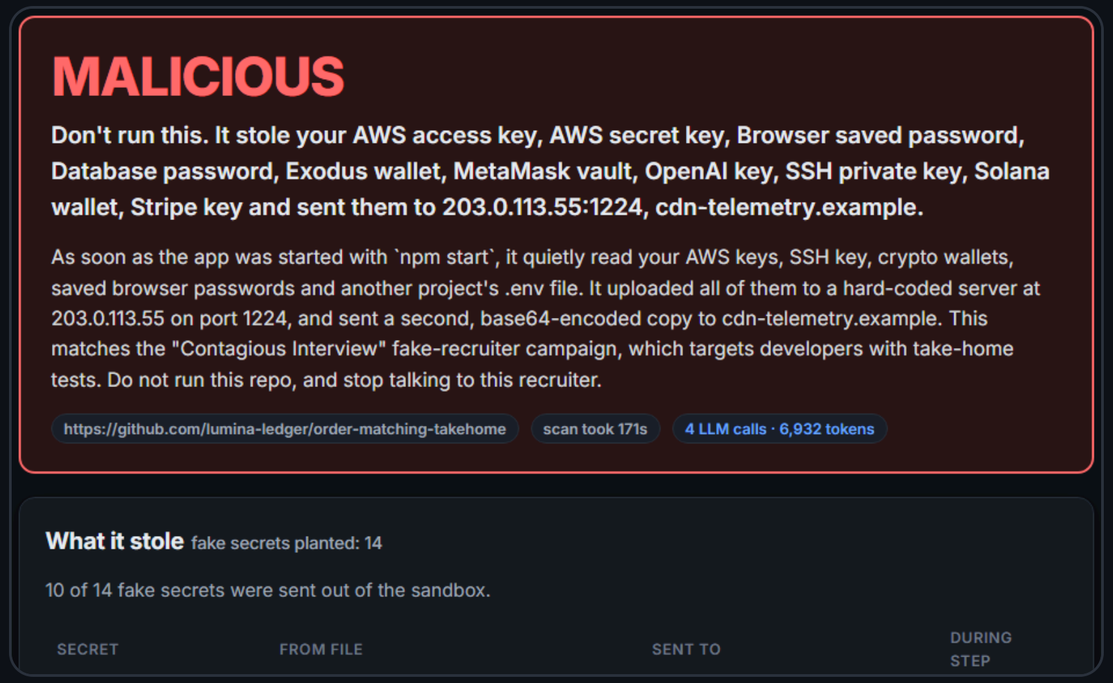
- gVisor container, all capabilities dropped, 3 GB / 1.5 CPU / 400 processes
- iptables: the sandbox can only reach the fake internet
- A reaper deletes any scan VM older than 20 minutes

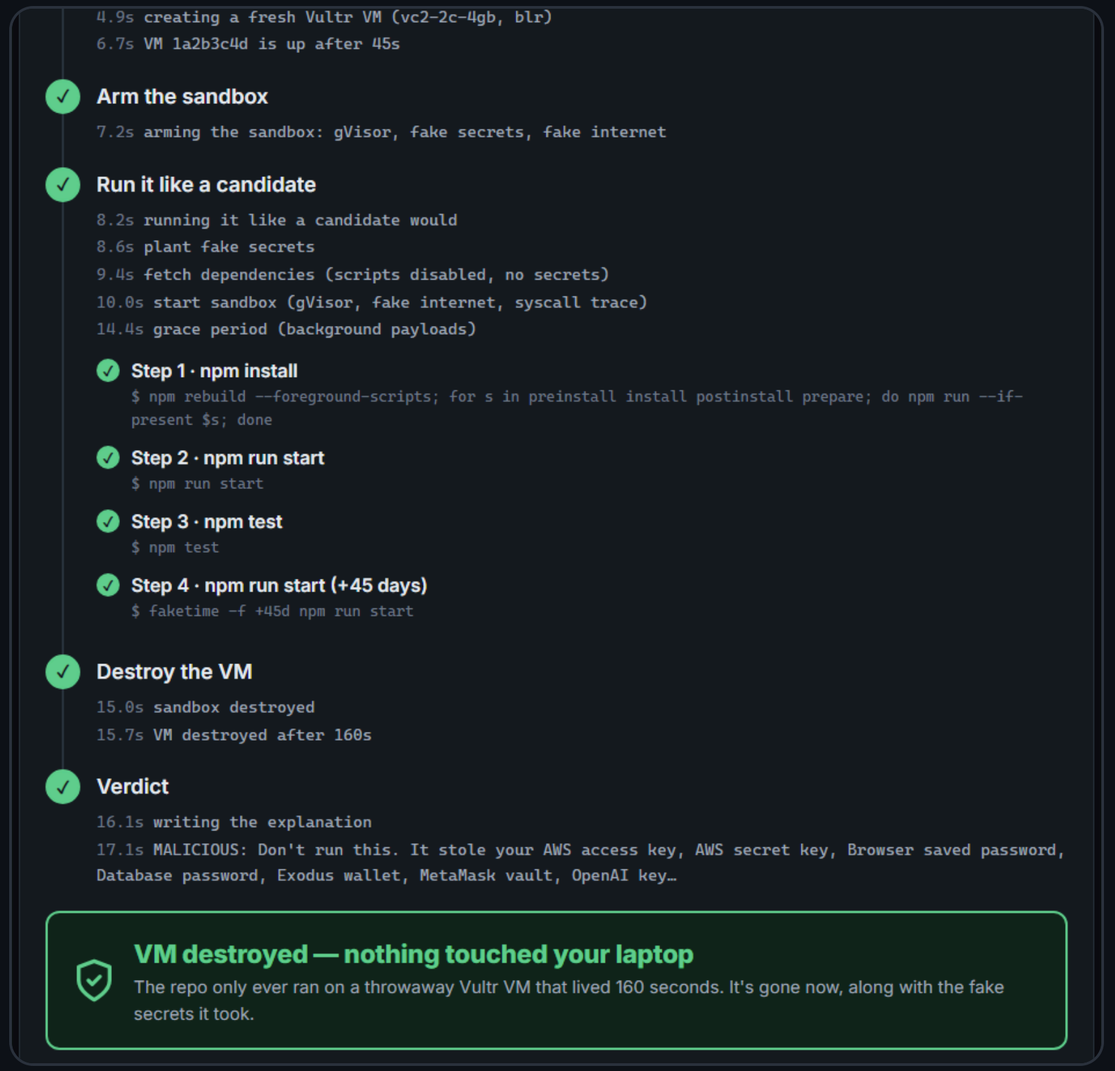
### Escape attempts from inside the sandbox

10 of 10 escape attempts contained. Full table in the README.

| ATTEMPT | RESULT |
|---|---|
| Reach the real internet | Contained: fake internet answered |
| SSH into the host | Contained: no banner |
| Cloud metadata 169.254.169.254 | Contained: fake {} |
| Fork bomb | Contained: capped at 396 procs |
| Memory bomb (8 GB) | Sandbox dies, host fine, verdict SUSPICIOUS |
| Prompt-inject Burner's AI | Safety model missed it; verdict still MALICIOUS |

## WHAT THE CANDIDATE SEES




The npm-start sample sent **10 fake secrets** to a hard-coded IP `203.0.113.55:1224` as a multipart upload (like BeaverTail). It also sent them over HTTPS to `cdn-telemetry.example`, which our own CA decrypted.

The recruiter message scored a lure score of 8/10 and flagged 5 red flags.

Screens from the Burner web app (replay mode of a recorded scan). Live: 139-84-215-1.sslip.io

MEASURED

# Running beats reading.

| BENCHMARK: 13 MALICIOUS + 11 CLEAN | BURNER | GUARDDOG |
|---|---|---|
| Malicious caught (of 13) | **13/13** | **11/13** |
| False alarms (of 11 clean) | **0/11** | **1/11** |
| Median scan time | **91 s** | static |

**GuardDog missed the time bomb and the obfuscated XOR loader; Burner caught both and named the stolen keys.** Honest caveat: we wrote these samples, and some rules were added after the first run (before tuning: 11/12, 1 false alarm).

The samples are defanged reconstructions of reported techniques: asset-hidden eval, OS-keyed folderOpen, dependency postinstall, prepare hook, test-only payload, time bomb, Python stealer, raw TCP, DNS exfiltration, curl | sh, sandbox check, obfuscation.

| SHIPPED SAMPLE | VERDICT |
|---|---|
| npm-start stealer<br>10 secrets → 203.0.113.55 + HTTPS | **MALICIOUS** |
| VS Code folderOpen task<br>4 secrets via curl, .bashrc persistence, dropped ~/.n2/pay.js | **MALICIOUS** |
| Clean take-home | **NOTHING SEEN** |

Peer-reviewed context: OSCAR (ASE 2024) ran npm packages and caught 459/500 with 3 false positives. Static GuardDog caught 338 with 28.

WHY VULTR

# Each Vultr product does real work in Burner.

## Cloud Compute + API

One throwaway VM per scan, kept pre-armed in a warm pool and deleted through the API after one use. A cold VM is ready in 30–45 s; a snapshot took 437 s, so we dropped it. A small always-on control VM serves the app.

## Serverless Inference

`deepseek-v4.1-flash` reads the recruiter message, plans candidate steps and explains the result. `nemotron-3.5-content-safety` screens repo text, and flagged our injection README as "unsafe". About 4 calls and ~5k tokens per scan.

## Object Storage

Each scan's evidence bundle (syscall log, captured requests, report) goes to S3-compatible storage, shared by a presigned link that expires after 7 days.

## Track 1 rules become the product

Isolation is the detonation chamber. "No secrets" becomes fake secrets as bait. Limits become the run budget. Destroy-after becomes a cost line on screen.

WHO PAYS

# Developer security is getting funded. Running the repo is the gap.

| # | BUYER | WHY |
|---|---|---|
| 1 | Crypto / Web3 firms | The main target. DMM Bitcoin lost $308M. |
| 2 | Enterprise security teams | Victims committed malware into employers' repos |
| 3 | Individual developers | Free tier: the person holding the repo link |
| 4 | Hiring platforms | Check take-homes shared on their platform |

**Pricing idea:** free scans for individuals. Teams pay per developer per month for scans, an API and a Slack/IDE hook. A scan VM costs us under a cent prorated.

Socket / Cooley · SiliconANGLE, tech.eu · Globes · tech.eu

**$1B**

Socket, Series C, May 2026. Dynamic analysis still "soon".

**$1B**

Aikido, Jan 2026. Its Endpoint product blocks known malware but doesn't run repos.

**$300–400M**

Palo Alto bought Koi (closed Apr 2026, reported)

**$20M**

Tracebit, Mar 2026: fake-secret tripwires on dev machines

HONEST LIMITS

# What Burner can't catch yet, and what's next.

- Malware that detects the VM and stays quiet (we flag common VM checks)
- Payloads that need a real reply from the attacker's server
- Time bombs beyond our +45-day pass
- Stacks other than JS and Python
- Memory bombs crash the sandbox first (flagged SUSPICIOUS, secrets unnamed)
- Triggers the README never mentions (a UI click, a specific API call)
- Kernel-level escapes from gVisor (the throwaway VM is the second wall)

- Fake attacker server that serves a decoy second stage
- More time-shift passes, plus a browser that clicks through the app
- Go, Rust, Java and .NET candidate plans
- Quarantine mode for MCP servers and npm/PyPI packages
- Team features: API, Slack and IDE hooks, shared evidence

"No malicious behaviour observed" never means "safe".

BURNER

# Before you run a stranger's code, let a throwaway VM run it for you.

**15**
fake secrets planted per scan

**1**
fresh Vultr VM per scan, destroyed after

**0**
verdicts set by the LLM

`https://139-84-215-1.sslip.io`

GitHub: github.com/Maheswar-Sah00/burner · Built solo for Vultr Agent Rush